

K.K. Wagh Institute of Engineering Education & Research

TY B.Tech — Artificial Intelligence & Data Science | Semester VI

Cloud Computing (2301315A)

UNIT V — SECURITY IN CLOUD COMPUTING

Comprehensive Exam-Ready Notes

CO5: Discuss risks, challenges, and security measures related to data confidentiality, integrity, and availability in the cloud.

Unit V — Syllabus Overview

Topic	Sub-topics
Risk Management	Comprehensive risk management, enterprise-wide risk management
Types of Risks	Privacy, Availability, Changes, Compliance risks in cloud
Data Security in Cloud	Security issues, challenges, advantages, disadvantages, CIA triad
Cloud Digital Persona & Data Security	Personas, content-level security
Cloud Security Services	CIA, identity, DLP, web security, email security, encryption, etc.
Secure Cloud Software Req.	Cloud access methods, VM architecture, multi-tenancy
Secure Cloud Software Testing	Cloud-based testing, TaaS, benefits

1. Risk in Cloud Computing

Definition: Risk in Cloud Computing

Being an on-demand availability of system resources, like computing power and data storage, cloud computing involves various types of risks that are grouped in different categories like privacy (involves risk like controlled Access, Segmentation, Risk with Sub letting services and ownership claim), availability (involves risk like service disruption), changes (involves risk like Changes in service and return of investment) and compliance (involves risk like Audit, storage location, and notification).

1.1 Risk Management

Risk Management in cloud computing is a structured process for identifying, assessing, and mitigating risks associated with cloud services. It must be integrated into the institution's overall enterprise risk management framework.

Risk Mgmt Component	Description
1. Comprehensive Risk Management	Involves detecting and assessing cyber risk and factoring it into the institution's total risk appetite. Incorporates cyber risk within enterprise risk management operations.
2. Cybersecurity	Organizations must create a comprehensive cybersecurity program focused on finding vulnerabilities, deploying protective solutions, detecting threats, and enabling system recovery from incidents.

3. Regulatory Compliance	Authorities worldwide release and update recommendations on cloud computing to prevent and respond to cyber-attacks. Without automation, maintaining a risk staff becomes very expensive.
4. Backup and Recovery	Cloud companies must conduct frequent backups AND frequent restoration testing to verify backup functionality. Policies may vary by cloud provider.
5. End-to-End Cyber Risk Framework	Involves creating a high-level strategic risk assessment tailored to company needs — no one-size-fits-all. Includes realistic budget and deployment planning.
6. Platform Support	Most cloud providers guarantee timely patching and updates. However, vulnerabilities exist in cloud providers too, and lack of visibility can be a risk.
7. Vendor Management	Third-party suppliers raise security concerns. Providers often undergo ISO, SOC 2, and FedRAMP audits. Require a lifecycle governance model for public cloud usage.
8. Cloud Migration	Process of transferring apps, data, or entire IT infrastructure to distant server facilities. Offers workload acceptance and rapid addition of services.

Best Practices for Cloud Computing Risk Management

1. Carefully select your CSP — conduct supplier risk evaluations for contract clarity, ethics, legal liability, viability, security, compliance, availability, and business resilience.
2. Establish adequate controls based on risk treatment — build robust data classification and lifecycle management methods. Include SLA provisions for data safeguarding and erasure.
3. Deploy technical safeguards — use a Cloud Access Security Broker (CASB) as an enforcement point for enterprise security policies when users access cloud-based resources.
4. Vendor management — consider building a public cloud strategy with security criteria for suitable SaaS usage and third-party audits.
5. Implement a comprehensive ERM framework — use COSO or ISO frameworks. GRC software can track and automate risk management tasks.

1.2 Enterprise-Wide Risk Management (ERM)

Definition: Risk (COSO 2004 Definition)

Risk is the possibility that an event will occur and adversely affect the achievement of objectives.

The types of risks in the cloud — security, integrity, availability, and performance — are the same as for non-cloud technology systems. However, an organization's risk profile changes when cloud solutions are adopted, depending on how and for what purpose they are used.

Major Enterprise Risks Identified in Cloud Computing

6. Unauthorized cloud activity

7. Lack of transparency
8. Security, compliance, data leakage, and data jurisdiction
9. Transparency and relinquishing direct control
10. Reliability, performance, high-value cyber-attack target
11. Vendor lock-in
12. Non-compliance with disclosure requirements
13. Non-compliance with regulations

1.3 Types of Risks in Cloud Computing

Cloud computing risks are broadly categorized into four groups:

Risk Category	Sub-Risks
Privacy	Controlled Access, Segmentation, Risks with Sub-letting Services, Ownership Claim
Availability	Service Disruption
Changes	Change in Service, Return on Investment
Compliance	Audit, Storage Location, Notification

Detailed Explanation of Each Risk Type

A. Privacy Risks

- **Controlled Access:** If an organization stores confidential data on the cloud, the cloud provider inherently has access to it. The service provider organization may access data stored by the customer.
- **Segmentation:** Due to the subscription-based multi-tenant nature of cloud computing, many subscribers share the platform, making data of one organization potentially accessible to another.
- **Risks with Sub-letting Services:** Cloud providers often build their services on top of other providers. Contractual agreements may not be fully transparent to end customers, leaving them unaware of who handles their data.
- **Ownership Claim:** If the service agreement is not carefully read, data ownership can unknowingly be transferred to the cloud provider, risking unauthorized data usage.

B. Availability Risk

- **Service Disruption:** All cloud transactions depend on internet connectivity. Any fault — degraded quality or complete outage — disrupts service. Cloud dependency without internet access means inability to process transactions or access critical data.

C. Changes Risks

- **Change in Service:** In a volatile market, cloud service providers may be acquired or shut down, causing unavailability of service with little notice.

- Return on Investment: If subscription costs are unexpectedly high, the core cost-effectiveness benefit of cloud computing is nullified.

D. Compliance Risks

- Audit: The service provider may not follow external audit processes, putting end customers in a vulnerable position.
- Storage Location: The physical location of stored data is unknown and could risk sensitive data being exposed to foreign or rival entities.
- Notification: Failure to provide transparent and timely breach notifications leaves customers unaware of compromises.

Enterprise-Level Risk Types (Detailed)

Risk Type	Description
1. Unauthorized Access to Business Data	Cloud services managing thousands of companies become a concentrated target. An attack at the CSP level affects all customers. Small businesses are targeted due to weaker controls; large companies due to higher payouts.
2. Cloud Vendor Security Risks	Third-party vendors can introduce risks through bankruptcy, lawsuits, or weak controls. Small SaaS startups may lack expertise to meet stringent control requirements.
3. Compliance Risks	Non-compliance with regulations like HIPAA, SOX, GLBA, or GDPR can result in liability even if the breach occurs at the CSP side. Proper legal contracts are vital.
4. Operational Control	When outsourcing to cloud, the organization loses direct control over IT infrastructure, tools, documents, and processes.
5. Availability Risks	Loss of internet access or CSP downtime (due to weather, DDoS attacks, or system failure) disrupts operations, especially for cloud-dependent companies.
6. Lack of Transparency	CSPs rarely disclose data storage locations, resource allocation algorithms, control mechanisms, or data segregation methods.
7. Reliability and Performance Issues	SLAs may not always be met when unexpected resource demands arise from other tenants or incidents in the cloud environment.
8. Vendor Lock-In	Proprietary cloud development tools may create applications that only work within that CSP's architecture, making it difficult to switch providers.
9. High-Value Cyber-Attack Targets	Consolidation of multiple organizations on a single CSP increases risk of confidentiality and data integrity breaches due to attractive attack targets.
10. Risk of Data Leakage	Multi-tenant environments where resources are shared present data leakage risks absent in dedicated server setups.
11. IT Organizational Changes	Adopting cloud reduces need for internal IT staff in infrastructure management, impacting morale and organizational structure.

12. CSP Viability

Many CSPs are relatively new companies. If they go out of business or curtail services, customers face disruptions or need to migrate — sometimes back to in-house systems.

2. Data Security in Cloud Computing

Definition: Cloud Data Security

Cloud data security is the combination of technology solutions, policies, and procedures that you implement to protect cloud-based applications and systems, along with the associated data and user access.

Cloud computing security refers to the act of protecting cloud environments, data, information, and applications against unauthorized access, DDOS attacks, malwares, hackers, and other similar attacks.

2.1 The CIA Triad (Core Principles)

Principle	Meaning
Confidentiality	Protecting the data from unauthorized access and disclosure.
Integrity	Safeguarding the data from unauthorized modification so it can be trusted.
Availability	Ensuring the data is fully available and accessible when it's needed.

⚠ Exam Note: CIA Triad is a fundamental concept — Confidentiality, Integrity, Availability. Definitions are as given in the slides; memorize them exactly.

2.2 Security Issues in Cloud Computing

Security Issue	Description
1. Data Loss	Also known as Data Leakage. Sensitive data is in the hands of a third party and the organization lacks full control. If cloud security is breached, hackers may gain access to sensitive data or personal files.
2. User Account Hijacking	The most serious security issue. If a user's or organization's account is hijacked, the hacker gains full authority to perform unauthorized activities.
3. Insecure APIs	APIs are the primary way to communicate with cloud services. Public APIs in the cloud domain are vulnerable. Hackers can exploit insecure APIs to access and harm data.
4. Lack of Skill	Inadequately skilled employees make cloud migration, feature adoption, and provider switching difficult — creating significant security gaps.

5. Vendor Lock-In (Changing Providers)	Switching from one CSP to another (e.g., AWS to Google Cloud) involves data migration challenges, compatibility differences, and varying pricing structures.
6. Denial of Service (DoS) Attack	System receives excessive traffic causing data loss. Common targets include banking and government sectors. Recovery requires significant money and time.

2.3 Types of Cloud Computing Security Controls

Control Type	Description
1. Deterrent Controls	Designed to block nefarious attacks on a cloud system. Particularly useful against insider attackers.
2. Preventive Controls	Make the system resilient to attacks by eliminating vulnerabilities.
3. Detective Controls	Identify and react to security threats. Examples include Intrusion Detection Software (IDS) and network security monitoring tools.
4. Corrective Controls	Activated after a security attack to limit the damage caused.

2.4 Importance / Advantages of Cloud Security

Benefit	Explanation
Centralized Security	Cloud security centralizes protection across all devices and endpoints, improving traffic analysis and web filtering while reducing policy and software update overhead.
Reduced Costs	Investing in cloud security reduces hardware expenditure and administrative manpower requirements.
Reduced Administration	Eliminates manual security configurations and constant security updates, making organizational management easier.
Reliability	Cloud services are highly reliable and accessible from anywhere with any device, given proper authorization.
Efficient Recovery	Cloud computing enables faster and more accurate recovery of applications and data, with minimal downtime.
Openness / Accessibility	Cloud frameworks ensure constant application availability, enabling collaboration and sharing across locations.
No Physical Infrastructure Required	Cloud storage eliminates the need for physical storage infrastructure.
Preferred Position (Ease of Execution)	Organizations can maintain applications and workflows without managing back-end complexities.
Cost per Head	Development overhead is minimized; cloud resources scale as the organization grows (add or subtract as needed).

2.5 Disadvantages of Cloud Security

Disadvantage	Explanation
Bandwidth Issues	Perfect execution requires distributing servers and storage across data centers; packing too many into small centers causes performance issues.
Without Excess / No Redundancy	Cloud servers may not be redundant or backed up by default. Technology failures can occur, and purchasing redundancy involves additional cost.
Data Transfer Capacity Issues	Large-scale data transfer across server farms can be bottlenecked if not planned adequately.
Loss of Control	Moving to cloud means shifting data control to the provider. Internal IT teams lose the ability to independently handle all issues.

2.6 Challenges of Cloud Security

- 14. Control over cloud data
- 15. Misconfiguration
- 16. Ever-changing workload
- 17. Access Management
- 18. Disaster recovery

3. Cloud Digital Persona and Data Security



Definition: Cloud Digital Persona

A digital persona in cloud context refers to a structured representation of target user profiles that guide how cloud-based systems, applications, and security policies are designed and tested. Personas help optimize digital strategy by shaping access, segmentation, and content delivery.

Four areas where personas are important in optimizing your digital strategy:

Persona Role	Description
1. Sharing Knowledge Between Teams	Personas ensure consistency across departments — marketing, sales, customer service, and stakeholders share a unified understanding of user engagement goals.
2. Enabling Design and Testing	A clear persona picture enables design of sites, landing pages, and communications that guide the customer journey. A/B testing can verify persona accuracy.

3. Supporting Segmentation and Targeting	Personas help identify and refine different user segments, enabling delivery of appropriate content to the right audience based on behavior and intent.
4. Supporting Campaign Creation	Personas help determine content that resonates with target audiences and guide ad placement decisions for maximum impact.

3.1 Content Level Security

Definition: Content Level Security (Asset-Based Security)

Message content is a significant attack vector used by malicious API consumers. API Services provides a set of Policy types to mitigate the potential for your backend services to be compromised by attackers or by malformed request payloads. Content-based security, also known as asset-based security, is a general term for security features that are embedded within the content itself.

Content-level security protects cloud services by securing the data/messages being transmitted rather than just the channel. Policy enforcement at the API gateway layer prevents malicious payloads from compromising backend services.

4. Cloud Security Services

Cloud Security Services are specialized service offerings from cloud providers that help protect cloud-based environments, data, and applications. These services address the core security requirements of Confidentiality, Integrity, and Availability.

Service	Description
1. Identity and Access Management (IAM)	Provides control for secured management of identities and access. Includes people, processes, and systems for managing enterprise resource access. Ensures user identity is verified and correct access rights are granted.
2. Data Loss Prevention (DLP)	Protects data by providing pre-installed DLP software with a deployed set of rules to prevent unauthorized data exfiltration.
3. Web Security	Protects against malware entering through web browsing. Delivered via software/appliance installation or by redirecting web traffic to the cloud provider.
4. E-mail Security	Controls inbound and outbound emails to protect against malicious attachments and phishing. Enforces policies on spam, acceptable use, and business continuity. Uses digital signatures for identification and non-repudiation.
5. Security Assessment	Tools for SaaS delivery model users including variant elasticity, low administration overhead, negligible setup time, and pay-per-use with low initial investment.

6. Intrusion Management	Uses pattern recognition to detect and react to statistically unusual and unexpected events. May require real-time reconfiguration of system components to prevent intrusion.
7. Security Information & Event Management (SIEM)	Gathers log and event information, correlates and analyzes it, and provides real-time reporting and alerts on events requiring intervention.
8. Encryption	Applies computationally difficult or nearly impossible to break algorithms to protect data at rest and in transit.
9. Disaster Management	Ensures business continuity and disaster recovery by providing flexibility and reliable failover for services during interruptions.
10. Network Security	Provides address security controls through virtual devices in the cloud environment to protect the underlying network infrastructure.

⚠ Exam Note: For '5 marks' questions on Cloud Security Services, write any 5 services with their definitions. For 10 marks, write all 10 with explanation.

4.1 Security Authorization Challenges in the Cloud

Authorization in the cloud faces several unique challenges:

- The multi-tenant nature makes it difficult to enforce strict boundaries between user data and access privileges.
- Role Name Conflicts arise in multi-tenant environments where the same role name may exist across different tenants with different permissions.
- Cross-Level Management issues occur when access control hierarchies span multiple tenants or service layers.
- Composition of tenants' access control is complex as policies from multiple organizations must coexist without conflict.
- Solutions include SaaS Role Based Access Control (S-RBAC), reference architectures with interoperable security, and differentiation between 'home cloud' and 'foreign cloud'.

5. Secure Cloud Software Requirements

Secure cloud software requirements are governed by three key areas:

5.1 Method of Access to the Cloud

Cloud environments are primarily accessed by Cloud Service Users (CSUs) through web applications, which are considered the weakest point of cloud computing. Browser-based authentication protocols are insecure because browsers cannot issue XML-based security tokens independently.

Technical solutions include: encrypting data while stored under the custody of a cloud service provider, and encrypting data while it is being transmitted to a CSU.

5.2 Architecture of the Cloud

The biggest architectural challenge is Virtual Machine (VM) instance interconnectivity. A key concern in virtualization is isolation — one VM must not be able to affect another VM running on the same host.

When multiple VMs share the same hardware (common in cloud environments), one VM could potentially be accessed illegally through another VM.

Solution: Virtual Network Framework consisting of three layers — routing layer, firewall, and shared network — to control intercommunication among VMs with higher security.

5.3 Features of Multi-Tenant Environment

Requirements must address problems specific to multi-tenant environments, including role name conflicts, cross-level management, and composition of tenants' access control.

Solutions include:

- SaaS Role Based Access Control (S-RBAC) model
- Reference architecture with 'interoperable security'
- Differentiation between 'home cloud' (primary CSP unable to meet demand, forwards requests) and 'foreign cloud' (partner CSPs that provide additional virtualization infrastructure)

6. Secure Cloud Software Testing

Definition: Cloud Testing

Cloud Testing is one type of software testing in which the software applications are tested by using cloud computing services. Cloud testing intends to test the software based on functional and non-functional requirements using cloud computing services that ensure faster availability, scalability, and flexibility that saves time and cost for software testing.

Definition: Cloud-Based Software Testing

Cloud-based software testing is a set of procedures, tools, and processes that are leveraged by testers to efficiently and precisely test software. With the utilization of Cloud service models, enterprises can implement testing as a service, without the need to completely invest in testing labs, tools, or infrastructure.

Without a proper test, the software will always be vulnerable to threats, errors, security breaches, and many other factors that significantly affect customer experiences. When selecting test tools from the cloud, testers must evaluate platform compatibility, resource support, flexibility, and service cost.

6.1 Benefits of Cloud-Based Software Testing

Benefit	Description
1. Reduced Cost & Resource Sharing	Cloud-based Testing as a Service (TaaS) enables IT teams and developers to run tests without buying licenses or resources. Pay only for what you use, reducing testing expenses significantly.

2. Better Testing Environment	Cloud provides a better virtual environment for testing with SaaS solutions covering the entire testing lifecycle. Enterprises access TaaS globally without physical infrastructure.
3. Pay Per Use Policy	Enterprises pay only for the time they use the testing resources. They can stop leveraging cloud services once testing is complete — far more cost-effective than traditional testing.

⚠ Exam Note: Enterprises must carry out robust QA planning to guarantee cloud services cover the entire test automation process. Enterprises must also be aware of growing regulatory scrutiny of cloud testing strategies covering data, flexibility, and application exit.

7. Quick Revision Glossary

Term	Definition
CIA Triad	Confidentiality, Integrity, Availability — the three pillars of information security in the cloud.
Risk Management	Process of detecting, assessing, and mitigating cyber risks in cloud environments.
ERM	Enterprise-Wide Risk Management — integrates cloud cyber risk into the organization's overall risk strategy.
COSO	Committee of Sponsoring Organizations — provides a comprehensive ERM framework.
CSP / CSU	Cloud Service Provider / Cloud Service User.
CASB	Cloud Access Security Broker — enforcement point between cloud service users and providers.
Deterrent Control	Blocks nefarious attacks, effective against insider threats.
Preventive Control	Removes vulnerabilities before they can be exploited.
Detective Control	Identifies and reacts to threats (e.g., IDS, SIEM).
Corrective Control	Limits damage after a security incident occurs.
Data Leakage / Data Loss	Unauthorized exposure of sensitive data due to cloud security breach.
DoS Attack	System receives excessive traffic causing data loss and downtime.
Vendor Lock-In	Difficulty in switching CSPs due to proprietary tools and data dependencies.
S-RBAC	SaaS Role Based Access Control — manages multi-tenant access control in cloud.
TaaS	Testing as a Service — cloud-based software testing without owning infrastructure.
IAM	Identity and Access Management — verifies user identity and manages access rights.
DLP	Data Loss Prevention — prevents unauthorized exfiltration of data.
SIEM	Security Information and Event Management — real-time log analysis and alerting.
VM Isolation	Guarantee that one Virtual Machine cannot affect another on the same host.
Virtual Network Framework	3-layer (routing, firewall, shared network) solution for secure VM intercommunication.

Content Level Security	Security embedded in message/data content itself to prevent API-level attacks.
Community Cloud	Cloud environment accessible to a limited set of organizations or employees.
Digital Persona	Structured user profile used to guide cloud system design, security, and personalization.
FedRAMP	Federal Risk and Authorization Management Program — US government cloud security standard.
SOC 2	Service Organization Control — third-party security audit standard for cloud providers.

8. Probable Exam Questions

Marks	Question
5	What is Risk in Cloud Computing? Explain the four categories of risk with examples.
5	Explain the CIA Triad as applied to Data Security in Cloud Computing.
5	What are the types of Cloud Computing Security Controls? Explain with examples.
10	Explain Enterprise-Wide Risk Management in Cloud Computing with the types of enterprise risks.
10	Discuss the Security Issues in Cloud Computing in detail.
5	What is Cloud Data Security? Explain its advantages and disadvantages.
5	Explain Cloud Security Services: Identity & Access, DLP, Web Security, and E-mail Security.
10	Write a detailed note on Cloud Security Services (any 8 services).
5	Explain Secure Cloud Software Requirements with respect to (a) method of access (b) cloud architecture.
5	What is Cloud-Based Software Testing? List its benefits.
5	What are the challenges of cloud security?
5	Explain 'Vendor Lock-In' and 'Vendor Management' as risks in cloud computing.
5	What is Content Level Security? What is Cloud Digital Persona?
10	Explain Risk Management in Cloud Computing covering all 8 components.
5	Differentiate between Deterrent, Preventive, Detective, and Corrective security controls.